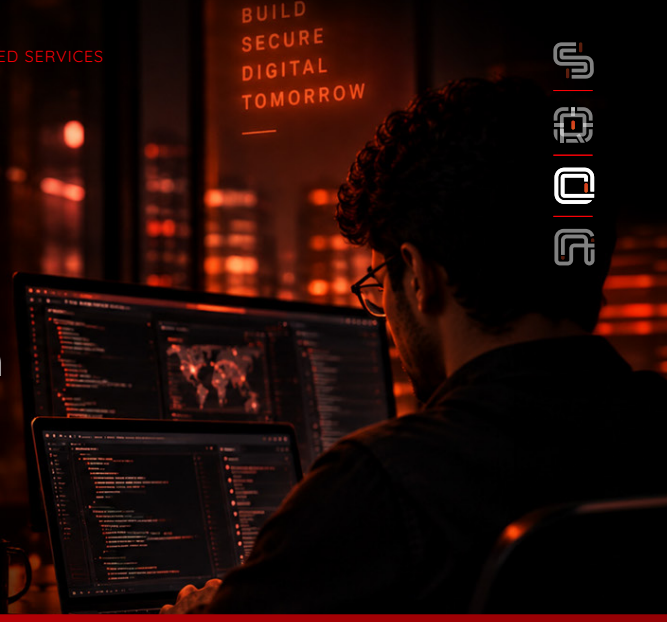
STHIROS
Strategy. Risk. Cyber. AI.



Identifying 9 OWASP Top 10 vulnerability categories across an IT company's web app and APIs

An IT and ITES company engaged Sthiros for comprehensive VAPT across its web application and integrated APIs, testing against every major OWASP Top 10 threat category.

Client	Service	Sector	Geography
An IT & ITES Company	**Vulnerability Assessment & Penetration Testing, Black Box & White Box**	**IT & IT-Enabled Services**	**Global**

The Challenge:

When a web app and its APIs have never been tested to the same standard

This IT and ITES company needed comprehensive VAPT of its web application and integrated APIs to identify security vulnerabilities and confirm protection against OWASP Top 10 threats before an attacker found them first.

Access Control & Authentication Failures

Improper authorisation checks combined with weak passwords and session management issues left access poorly governed across the application.

Cryptographic Failures

Weak encryption and exposed secrets left sensitive data inadequately protected in transit and at rest.

Injection Vulnerabilities

SQL injection and command injection vulnerabilities exposed the application to direct data and system compromise.

Insecure Design & Integrity Failures

Security requirements were never integrated into the SDLC, with unsigned code and insecure CI/CD pipelines compounding the exposure.

Misconfiguration & Outdated Components

Default credentials, unnecessary enabled features, and unpatched libraries and frameworks left known attack paths open.

Security Logging & Monitoring Failures

Inadequate logging and no alerting meant suspicious activity could pass through the environment undetected.

The Solution:

Automated scanning, manual verification, and API coverage in one engagement

Sthiros ran black box and white box VAPT across the web application and every integrated API, combining automated scanning tools with manual verification to confirm real exploitability, not just theoretical exposure.

Every finding was mapped to remediation guidance for its specific OWASP category, with secure SDLC and DevSecOps recommendations delivered alongside.

The Methodology

1

Web Application Black Box & White Box Testing

Combined black box and white box testing applied across the web application, replicating both external attacker and insider-knowledge perspectives.

2

Integrated API Security Testing

Every integrated API tested independently for the same OWASP-aligned vulnerability classes as the core web application.

3

Automated Vulnerability Scanning

Nessus, OWASP ZAP, OpenVAS, SQLmap, Metasploit, Hydra, Commix, and Kali Linux deployed to systematically scan for known vulnerability classes.

4

Manual Verification with Burp Suite

Burp Suite Professional used for manual verification and exploitation testing beyond what automated tools alone could confirm.

5

Remediation Guidance & Secure SDLC Recommendations

Findings mapped to remediation guidance for every OWASP category, with secure SDLC and DevSecOps recommendations delivered alongside.

What This Means

Patch what's outdated, not just new code.

Security belongs in the SDLC.

Log enough to notice an attack.

Outcomes

9

OWASP vulnerability categories identified

Spanning access control, cryptography, injection, design, and monitoring.

8

Automated security tools deployed

Including Nessus, OWASP ZAP, Metasploit, and SQLmap, layered with manual verification.

2 Months

Engagement duration

From testing scope definition through to remediation guidance.

Web App + API

Full-stack coverage

Both the core web application and every integrated API tested to the same standard.

Get in touch

Is your application stack tested, or just shipped?

Speak to Sthiros about what a structured VAPT programme can unlock for your application security posture.

Connect with us:
sthiros.com

STHIROS
Strategy. Risk. Cyber. AI.